

TP Cybersécurité – Campagne de Phishing avec GoPhish

Sommaire

Etape 1 : Installation de Gophish	2
Étape 2 : Configuration de base	2
1 – Créer un groupe d'utilisateurs cibles.....	2
2 - Créer une landing page (page de destination)	2
3 - Créer un courriel de phishing.....	2
Etape 3 : Lancer la campagne de phishing.....	3
1 - Associer le mail, la landing page et le groupe cible	3
2 - Démarrer la campagne	7
3 - Observer le tableau de bord : clics, soumissions d'identifiants	7
Étape 4 : Analyse des résultats	8
1. Observation des comportements	8
2. Interprétation	8
3. Identification des signaux d'alerte	8
Étape 5 – Sensibilisation	9
1. Pourquoi les attaques de phishing fonctionnent-elles encore ?.....	9
2. Contre-mesures à mettre en place	9
Mesures techniques	9
Mesures organisationnelles.....	9
Bonnes pratiques recommandées	10

Etape 1 : Installation de Gophish

Étape 2 : Configuration de base

1 – Créer un groupe d'utilisateurs cibles

Nous avons créés des boîtes mails de test et aussi utiliser celle des étudiants du groupe :

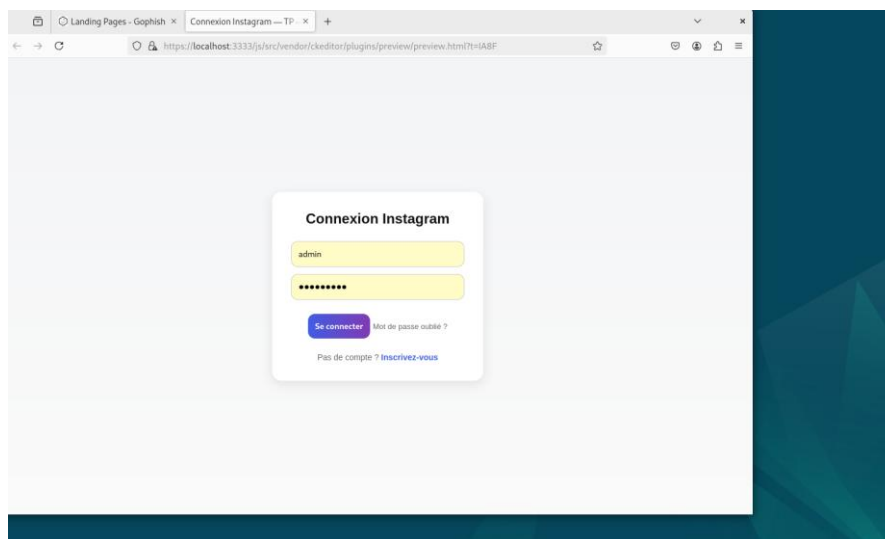
instagram.office.mdp@gmail.com (La boîte mail d'envoi)

testphishing1cyber@gmail.com (Notre boîte mail de test N°1)

testphishing2cyber@gmail.com (Notre boîte mail de test N°2)

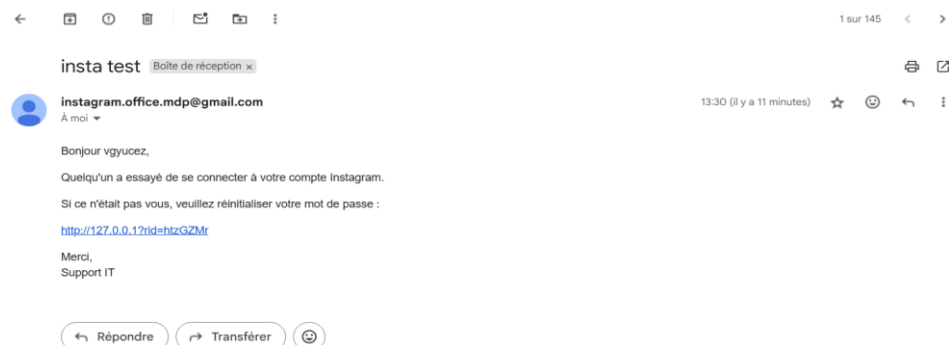
2 - Créer une landing page (page de destination)

Création de notre landing page en html imitant une page de connexion instagram :



3 - Créer un courriel de phishing

Exemple de ce que recevra la cible :

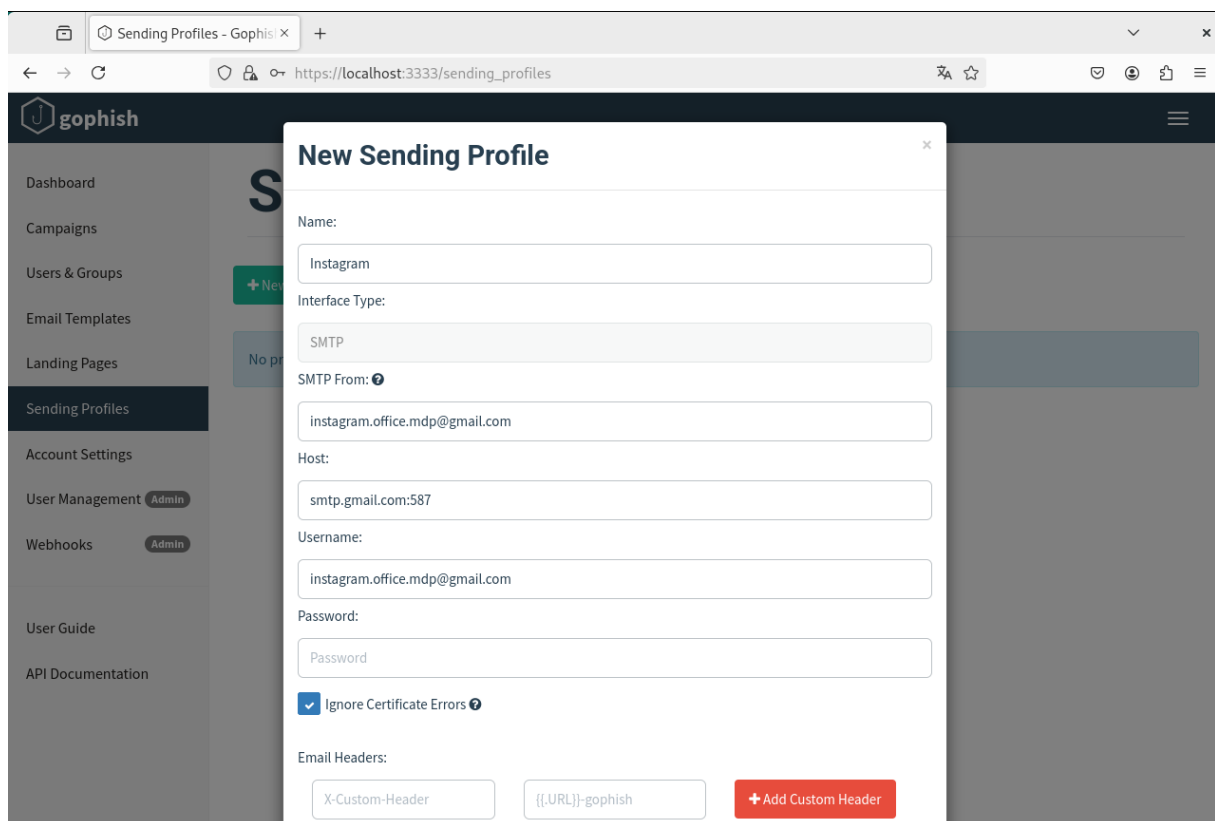


Etape 3 : Lancer la campagne de phishing

Voici toutes les étapes que nous avons réalisées avant de mettre en route l'envoi des mails pour la campagne de phishing :

1 - Associer le mail, la landing page et le groupe cible

Sending profil : Voici comment nous l'avons compléter avec toutes les informations nécessaire :

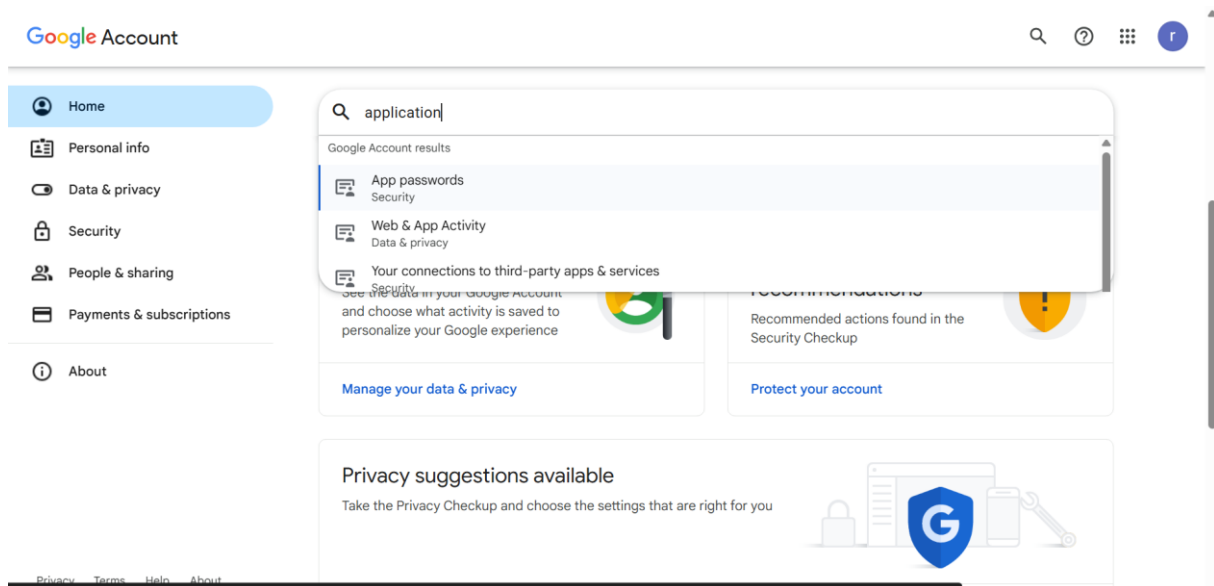


The screenshot shows the Gophish web interface in a browser window. The address bar indicates the URL is `https://localhost:3333/sending_profiles`. The left sidebar contains a navigation menu with the following items: Dashboard, Campaigns, Users & Groups, Email Templates, Landing Pages, Sending Profiles (highlighted), Account Settings, User Management (Admin), Webhooks (Admin), User Guide, and API Documentation. The main content area displays the 'New Sending Profile' form. The form fields are as follows:

- Name:** A text input field containing 'Instagram'.
- Interface Type:** A dropdown menu with 'SMTP' selected.
- SMTP From:** A text input field containing 'instagram.office.mdp@gmail.com'.
- Host:** A text input field containing 'smtp.gmail.com:587'.
- Username:** A text input field containing 'instagram.office.mdp@gmail.com'.
- Password:** A password input field with the placeholder text 'Password'.
- Ignore Certificate Errors:** A checkbox that is checked, with a help icon.
- Email Headers:** A section containing two input fields: 'X-Custom-Header' and '{{.URL}}-gophish'. To the right of these fields is a red button labeled '+ Add Custom Header'.

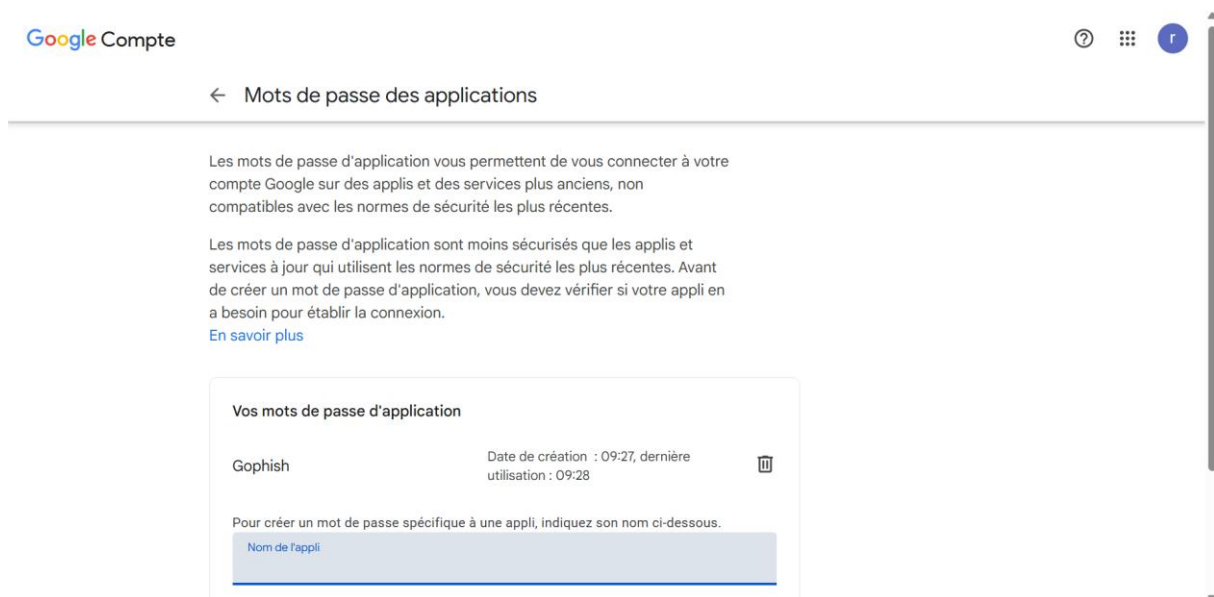
Pour le mot de passe il faudra aller sur le compte google utilisé pour envoyer les mails : instagram.office.mdp@gmail.com

Ensuite rechercher application gmail dans la barre de recherche pour rentrer dans mot de passe d'application



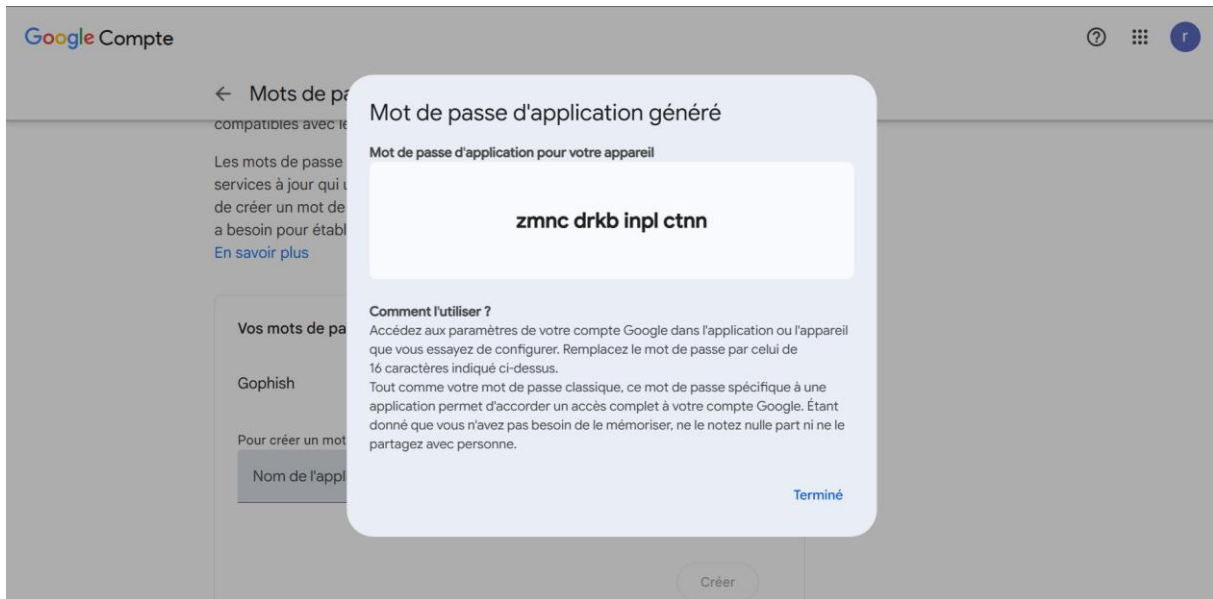
Après il faudra faire une double vérification par google pour pouvoir créer son mot de passe d'application.

Cela va nous amener ici :



On devra écrire le nom de l'appli (En option)

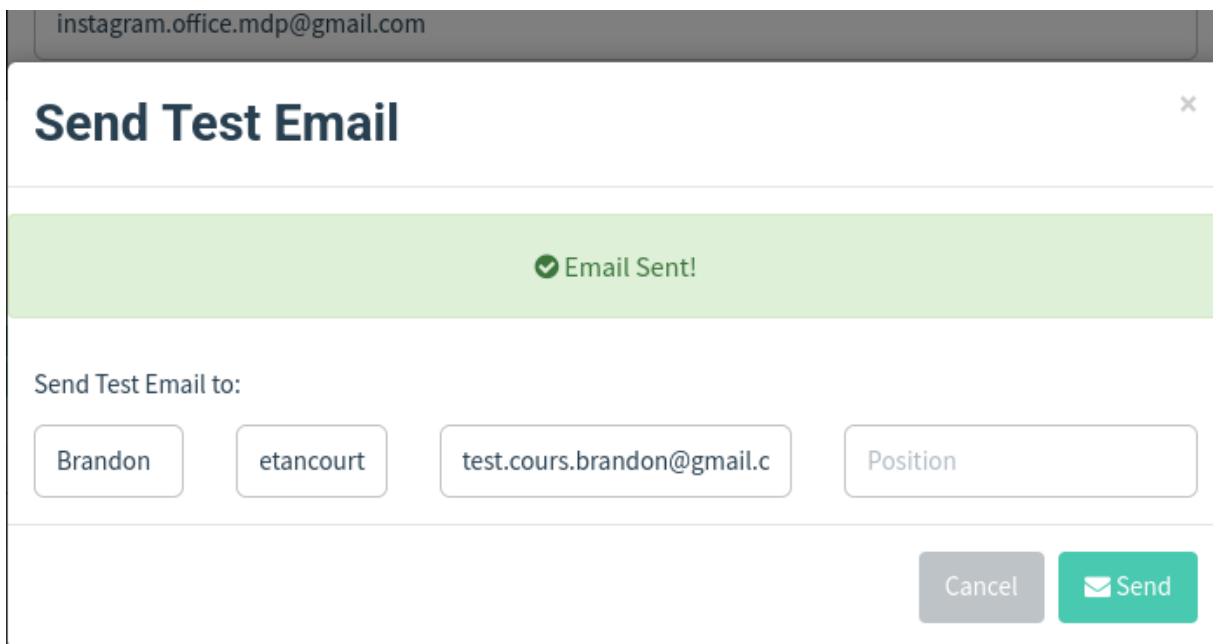
Et ça va nous créer un mot de passe qui faudra mettre dans password



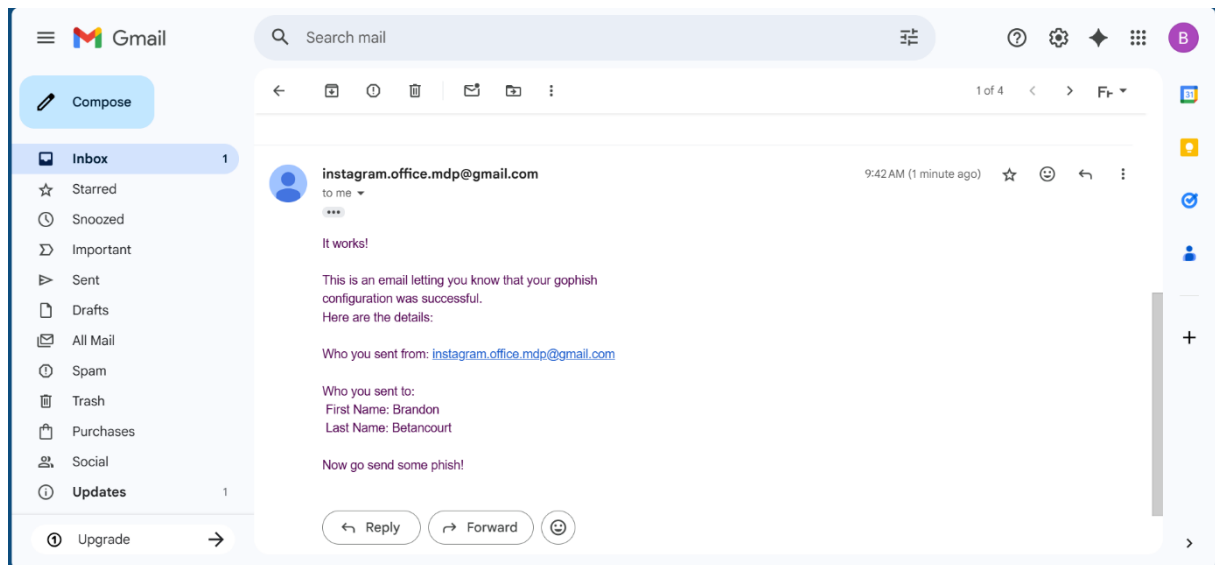
Et le mettre dans password du sending profil.

Après on effectue un test pour vérifier que tout est bon.

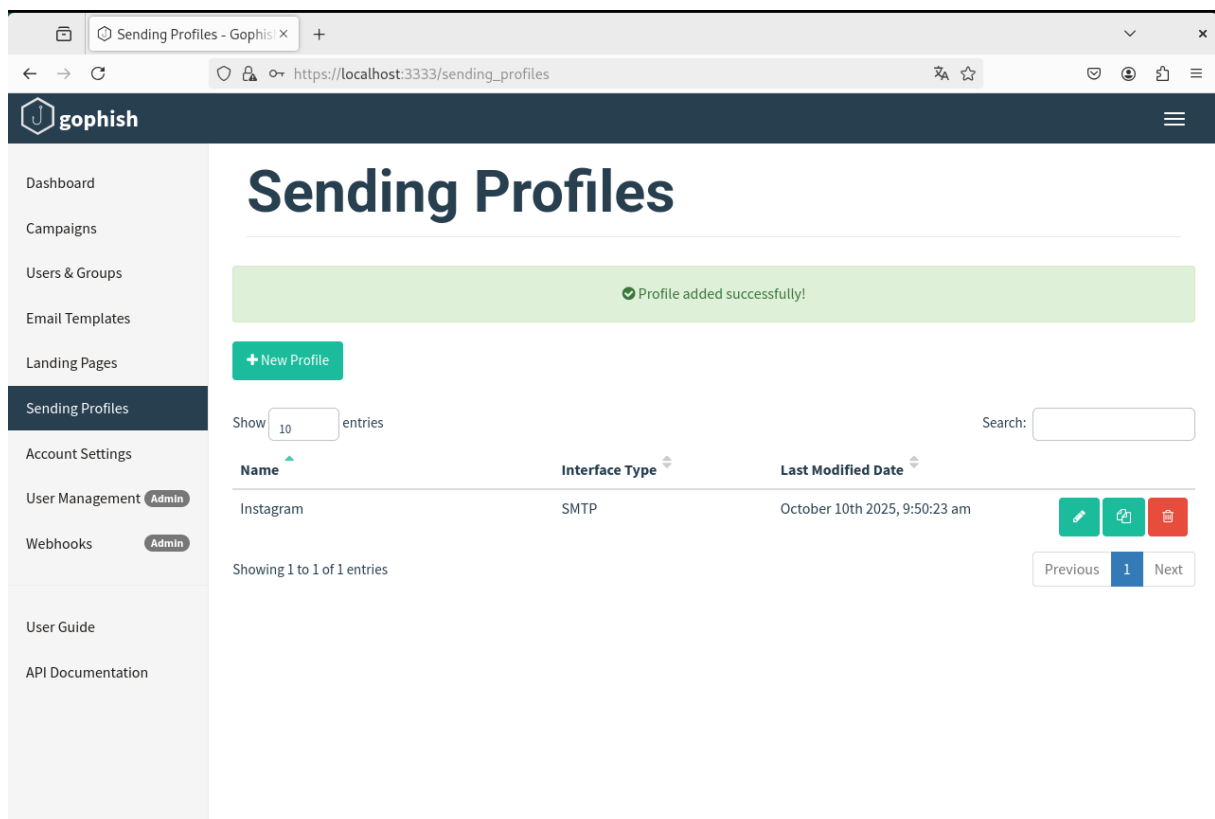
Si cela fonctionne l'application mettra « Email Sent ! » comme ici :



Cela veut dire que ça a fonctionné, il faudra juste aller sur le mail d'envoi et on verra un mail comme cela qui signifie que ça a fonctionné, alors on pourra mettre en marche la campagne :

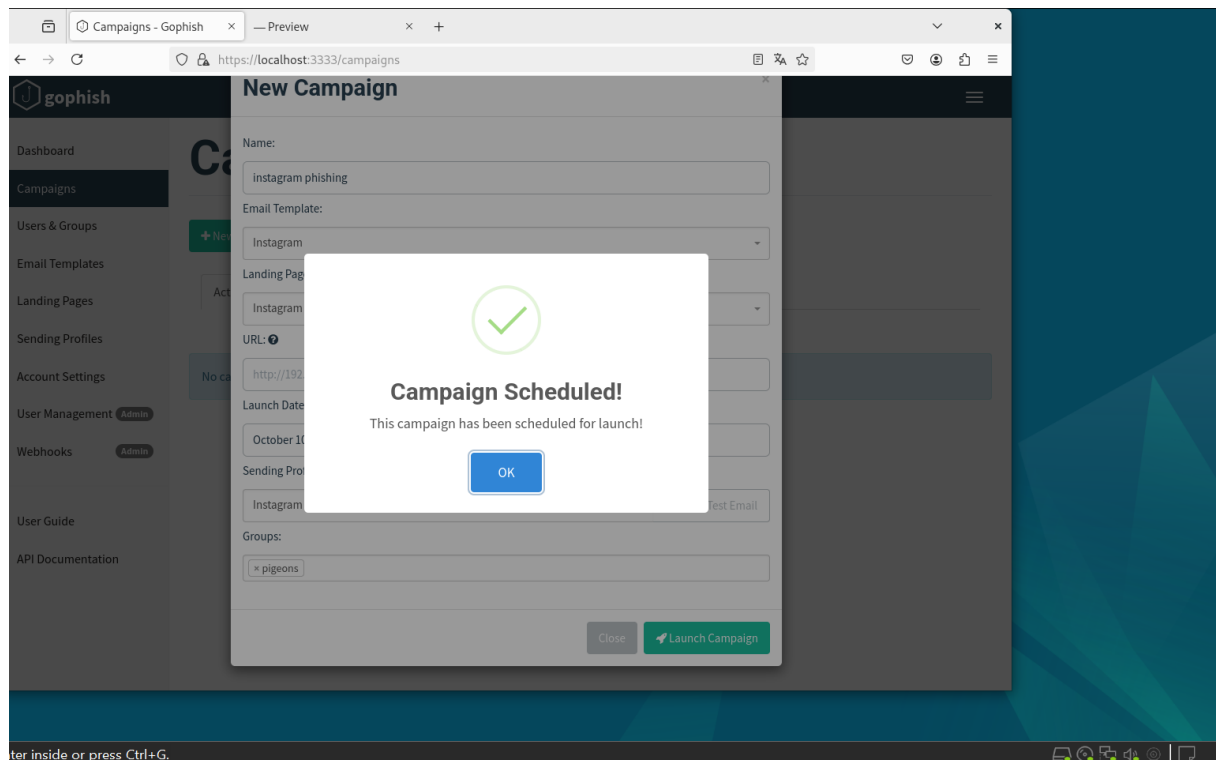


Après tout ça on a juste à enregistrer notre sending profile fonctionnel pour notre Campagne :



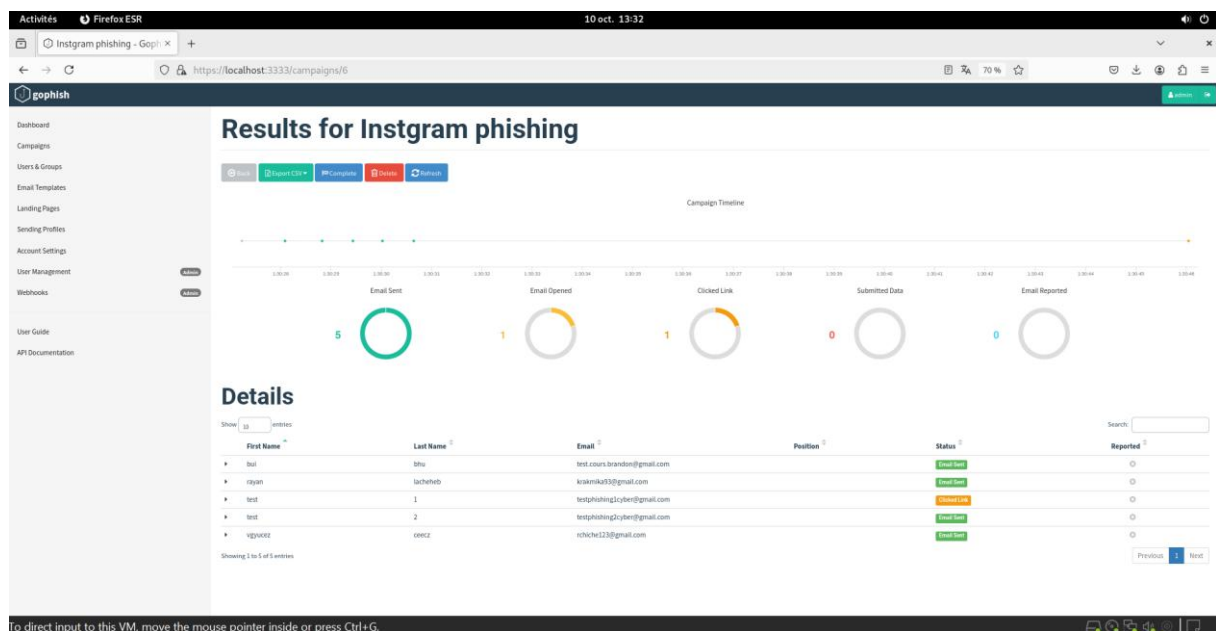
2 - Démarrer la campagne

Maintenant lançons la campagne et analysons nos résultats :



3 - Observer le tableau de bord : clics, soumissions d'identifiants

Voici les résultats de notre campagne après quelques temps.



Étape 4 : Analyse des résultats

1. Observation des comportements

L'analyse des résultats de la campagne de phishing simulée met en évidence les comportements suivants :

- **Clic sur le lien** : une personne a cliqué sur le lien contenu dans le message frauduleux.
- **Saisie de données** : aucune tentative de saisie de mot de passe ou d'autres informations sensibles n'a été observée.

Ces résultats traduisent une certaine vigilance au sein des utilisateurs, mais ils montrent également que le message de phishing a su convaincre au moins un destinataire de cliquer sur le lien.

2. Interprétation

Le fait qu'un utilisateur ait cliqué sur le lien indique que la campagne présentait des éléments crédibles, suffisants pour susciter la curiosité ou la confiance. Cela souligne la nécessité de poursuivre les actions de sensibilisation afin de renforcer la détection des signaux faibles d'une tentative de fraude.

3. Identification des signaux d'alerte

Lors du débriefing collectif, il est essentiel d'analyser les indices qui auraient pu permettre d'identifier le courriel comme suspect, notamment :

- **Présence de fautes d'orthographe ou de grammaire** dans le corps du message ou l'objet.
- **URL non conforme ou suspecte**, par exemple un nom de domaine légèrement modifié ou une adresse qui ne correspond pas au site officiel.
- **Tonalité alarmiste ou urgente**, incitant à agir rapidement sans réflexion.
- **Adresse de l'expéditeur inhabituelle ou trompeuse**, souvent proche de celle d'un service légitime.

Cette analyse collective permet de renforcer la capacité de chacun à reconnaître les tentatives de hameçonnage à l'avenir.

Étape 5 – Sensibilisation

1. Pourquoi les attaques de phishing fonctionnent-elles encore ?

Les attaques de phishing continuent d'être efficaces pour plusieurs raisons :

- Les **messages frauduleux sont de plus en plus sophistiqués**, imitant parfaitement les communications légitimes d'organisations connues.
- Les **utilisateurs sont souvent soumis à la pression temporelle**, ce qui réduit leur capacité à vérifier les détails.
- Le **manque de sensibilisation ou de formation continue** entraîne une baisse de vigilance.
- Le **facteur humain** reste la principale vulnérabilité des systèmes d'information.

2. Contre-mesures à mettre en place

Mesures techniques

- **Mise en place de filtres antispam et antivirus** pour limiter la réception de courriels frauduleux.
- **Filtrage DNS et blocage d'URL malveillantes** afin d'empêcher l'accès aux sites de phishing connus.
- **Authentification multifacteur (MFA)** pour réduire l'impact d'un éventuel vol de mot de passe.
- **Surveillance des journaux et alertes automatisées** en cas de comportements anormaux sur les comptes utilisateurs.

Mesures organisationnelles

- **Organisation régulière de campagnes de sensibilisation** internes simulant des attaques de phishing.
- **Mise à jour de la charte informatique** pour rappeler les obligations et bonnes pratiques de sécurité.
- **Formation continue du personnel** sur la détection des courriels suspects et la conduite à tenir.
- **Communication claire et non culpabilisante** après chaque campagne afin de favoriser l'apprentissage collectif.

Bonnes pratiques recommandées

- Vérifier systématiquement **l'adresse de l'expéditeur** et l'orthographe du nom de domaine.
- Ne jamais **cliquer sur un lien** ou **ouvrir une pièce jointe** provenant d'un message douteux.
- Utiliser le **mécanisme de signalement interne** pour reporter les tentatives de phishing.
- **Changer immédiatement son mot de passe** en cas de doute ou de clic sur un lien suspect.
- Se méfier des **messages évoquant une urgence, une menace ou une récompense inattendue**.
- Participer régulièrement aux **sessions de sensibilisation** proposées par l'entreprise.